



SentinelEdge Agent

Security Audit Report -- Windows Service Go Agent

Date: 2026-03-20 | Author: Claude Code Security Audit | CONFIDENTIAL

This report documents security findings for the SentinelEdge agent: a Windows Service written in Go installed on MSP-managed endpoints. The agent registers with the API, sends heartbeats, executes remote PowerShell commands, collects hardware/software inventory, and auto-updates from GitHub Releases. The review covers authentication, configuration, command execution, resilience, and TLS.

STACK	Go 1.21+ kardianos/service spf13/viper go-resty/resty google/uuid
API	https://saapi.ardepa.site Vault: https://pwd.ardepa.site
REPO	https://github.com/ardepa710/sentineledge-agent

0 CRITICAL	2 HIGH	2 MEDIUM	2 LOW
---------------	-----------	-------------	----------

Total findings: 6

Area	CRITICAL	HIGH	MEDIUM	LOW
Command Execution	--	1	--	--
Configuration	--	1	--	--
Auto-Update	--	--	1	--
Resilience	--	--	1	--
TLS Security	--	--	--	1
Token Management	--	--	--	1

HIGH**Command Execution****1. Arbitrary PowerShell execution without command whitelist****Why it matters:**

The agent executes any PowerShell script received from the server without content validation. If the API commands endpoint is compromised (via the DASHBOARD_API_KEY exposed in the browser bundle), an attacker can execute arbitrary code on all managed Windows endpoints, achieving full SYSTEM-level privilege escalation.

Recommendation:

Implement a whitelist of pre-approved scripts by SHA256 hash, stored in Vaultwarden. The agent must reject any script whose hash is not on the approved list and log the attempt to the API audit log.

HIGH**Configuration****2. VaultClientSecret stored in plaintext in agent.yaml****Why it matters:**

The Vaultwarden OAuth secret (VaultClientSecret) is saved in agent.yaml on the endpoint disk. Any local user with access to the installation directory can read it. With this secret, an attacker can authenticate to Vaultwarden and extract ALL registered agent tokens.

Recommendation:

Encrypt agent.yaml using Windows DPAPI in the service account context. Alternatively, store VaultClientSecret in the Windows Registry with a restrictive ACL (SYSTEM and SentinelEdgeAgent service account only).

MEDIUM**Auto-Update****3. SHA256 hash for auto-update comes from the same potentially compromised server****Why it matters:**

The update flow fetches version, hash, and download URL all from the same /version endpoint. If the API is compromised, an attacker can replace both the hash and the download URL to distribute a malicious executable to all agents -- a mass supply chain attack.

Recommendation:

Sign the executable with an Authenticode certificate. Verify the digital signature in addition to the SHA256. Publish the hash on an independent channel (e.g., GitHub Releases with a GPG signature) and compare against both sources before installing.

MEDIUM**Resilience****4. No exponential backoff in polling loop -- thundering herd risk****Why it matters:**

When the API is down, the agent retries at exactly 30-second intervals indefinitely. With many simultaneous agents, this generates a burst of load on the API the moment it recovers, potentially causing it to crash again.

Recommendation:

Implement exponential backoff with jitter: base 30s, multiplier 1.5x, cap 300s, plus a random +/- 10s offset per agent to prevent synchronization.

LOW**TLS Security****5. No certificate pinning against saapi.ardepa.site****Why it matters:**

The agent uses standard TLS without verifying the server certificate identity. An attacker with DNS or network access could perform MITM with a certificate from a different CA to intercept Bearer tokens and command responses.

Recommendation:

Implement certificate pinning: extract the public key hash from the current certificate and verify it in every connection via the crypto/tls VerifyPeerCertificate callback.

LOW

Token Management

6. Agent tokens have no expiration or automatic rotation

Why it matters:

Bearer tokens issued at registration are permanent. A compromised token grants indefinite access to the agent. The only revocation mechanism is deleting the agent record from the database.

Recommendation:

Implement 30-day token rotation: the agent sends its current token to obtain a new one. The API invalidates the previous token. Add an `expires_at` column to the agents table and reject expired tokens.

